

OPERATIONAL RUNBOOK

AWS Basic Foundations & Security Hardening

Nexlify Technologies | Platform Engineering | Document ID: NX-OPS-AWS-001 | Rev 3.2 | Effective 2026-06-15

1. Scope & Ownership

This runbook defines the mandatory baseline configuration for every AWS account owned by Nexlify Technologies. It applies to the primary production account (ACCT-884219037561), the shared services account (ACCT-771203948512), and all non-production sandbox accounts. Primary region is ap-south-1 (Mumbai). Availability Zones in use: ap-south-1a (primary, preferred for stateful workloads) and ap-south-1b (secondary). Platform Engineering owns the enforcement of these controls; individual squads own day-to-day resource compliance inside their namespaces. Any deviation requires a documented exception ticket in the Change Advisory Board (CAB) queue with approval from the Cloud Security Lead. The document is reviewed quarterly or after any AWS Organizations SCP change.

2. Root Account & MFA Enforcement

Root user credentials for every Nexlify AWS account are stored exclusively in the corporate password vault (HashiCorp Vault path: secret/aws/root/). Root login is prohibited for operational tasks. Hardware MFA (YubiKey 5 NFC) is mandatory for the root user; virtual MFA is not accepted. The Cloud Security team rotates the root password every 90 days and validates MFA device presence during the monthly access review. Emergency break-glass procedure is documented in the Incident Response playbook (NX-SEC-IR-004). All root console sessions generate an immediate high-severity CloudWatch alarm that pages the on-call security engineer. IAM Identity Center (SSO) is the sole supported method for human interactive access. Direct IAM user creation is blocked by SCP except for a small set of break-glass service accounts.

3. AWS IAM Identity Center (SSO) Configuration

Nexlify uses AWS IAM Identity Center integrated with Okta as the external identity provider. Permission sets are defined centrally: PlatformAdmin, NetworkOperator, EKSOOperator, ReadOnlyAuditor, and BillingViewer. Assignment of permission sets to Okta groups is managed via Terraform (module terraform-aws-sso). Session duration is capped at 4 hours for production accounts and 8 hours for non-production. Attribute-based access control (ABAC) tags (CostCenter, Team, Environment) are required on every permission set. Temporary elevated access for production troubleshooting uses the AWS IAM Access Analyzer and a just-in-time request workflow that expires after 2 hours. All SSO login events are forwarded to the central SIEM (Splunk) via CloudTrail.

4. CloudTrail Organization Trail

An organization-level CloudTrail trail named 'nexlify-org-trail' is enabled in the management account and propagates to every member account. Multi-region trail is required; global service events are included. Log file validation is turned on. Delivery is to a central S3 bucket (s3://nexlify-cloudtrail-ap-south-1) with Object Lock in COMPLIANCE mode (retention 2555 days). SSE-KMS encryption uses a customer-managed key owned by the Security account. CloudWatch Logs integration is enabled with a 90-day retention period for near-real-time alerting. Athena tables are maintained for ad-hoc investigation. Any attempt to stop or delete the trail is denied by SCP and generates a critical security finding.

5. AWS Config Rules & Conformance Packs

AWS Config is enabled in every account and region. The operational conformance pack 'Nexlify-CIS-Foundations' includes rules for: root MFA, IAM password policy, S3 public access block, EBS encryption by default, RDS encryption, VPC flow logs, restricted SSH, and unused credentials. Config aggregator is deployed in the Security account for multi-account visibility. Non-compliant resources are automatically tagged with ComplianceStatus=NonCompliant and appear on the weekly Platform Ops dashboard. Remediation is performed via SSM Automation documents where safe; otherwise a Jira ticket is opened against the owning team. Config snapshots are delivered daily to the same central S3 bucket used by CloudTrail.

6. Region & Availability Zone Strategy

All new workloads must be launched in ap-south-1. Cross-region replication is permitted only for disaster recovery copies of critical data stores and must be approved by Architecture Review Board. Within ap-south-1, ap-south-1a is designated primary AZ for stateful services (databases, Redis, Kafka brokers) to minimise cross-AZ data transfer charges. ap-south-1b serves as the secondary AZ for high-availability pairs. Stateless compute may span both AZs freely. The default VPC in every account is locked: no ENI, no EC2, no Lambda, no RDS may be created inside it (enforced by SCP).

Operational VPCs are created via the standard Terraform module described in the VPC runbook.

7. Operational Checklist (Monthly)

- Verify root MFA device is present and functional for all accounts.
- Confirm organization CloudTrail is logging and S3 delivery has no failures.
- Review AWS Config non-compliant resources and close or escalate findings older than 14 days.
- Validate SSO permission set assignments against current Okta group membership.
- Ensure no resources exist in any default VPC (Config rule + manual spot-check).
- Check that GuardDuty, Security Hub, and IAM Access Analyzer are enabled and findings are triaged.

Contact: platform-ops@nexlify.io | Slack: #platform-ops | On-call: PagerDuty service 'Platform Engineering'. This document supersedes NX-OPS-AWS-001 Rev 3.1. Change history is maintained in Confluence space PlatformOps.